Software Defined IoT Security Framework

Ola Salman Imad Elhajj Ali Chehab Ayman Kayssi
Department Electrical and Computer Engineering
American University of Beirut
Beirut 1107 2020, Lebanon
{oms15, ie05, chehab, ayman}@aub.edu.lb

***Abstract*— The requirements of the fifth generation of mobile communications technology (5G) present many challenges. Among others, it aims at improved support of device-to-device communication, lower cost, lower latency than 4G and lower battery consumption, for better implementation of the Internet of things (IoT). However, the connectivity of IoT devices gives rise to additional security and privacy concerns. Given the associated data proliferation and the integration of third-party applications, the access control management becomes an exceedingly complex task. Thus, a security model is needed. Few years ago, the "softwarization" invasion along with the network "virtualization" have led to a new network control paradigm and paved the way towards a global network operating system. In this paper, we discuss the IoT requirements in terms of security and privacy. Additionally, we propose an IoT software defined security framework.**

Keywords—SDN, IoT, Authentication, Access Control, Security.

I. Introduction

The increase in connected devices and device to device communication has been referred to in many way: Internet of Thing (IoT), Internet of Everything (IoE), Internet of Anything (IoA), Machine-to-Machine (M2M), Industrial Internet of Things (IIoT), etc. The common aspect between all these terms is the connection of new kinds of objects to the Internet in order to build a connected world.

In the IoT technology, every "thing" has to be uniquely identified and accessible. Such a task, with the proliferation of wireless sensors and wireless communication technologies, is challenging given the different silos of **heterogeneous** networks. In addition, Metcalfe's law states that the value of a telecommunication network is exponentially proportional to the number of its connected users. About 50 billion of things will be connected to the global network by 2020 as stated by Cisco. This **large scale** will impact QoS and management as we know them in today's networks. Furthermore, IoT applications typically result in **large volumes** of data, requiring new ways of logging and analyzing. Finally, the **security and privacy** concerns are ones of the most important challenges facing the IoT proliferation. Having billions of things connected to the Internet sending real-time data calls for special considerations. Having different types of data with different levels of criticality, from entertainment to medical, we need to establish a security model to ensure proper data access and handling. To complicate matters further, the "things" power consumption and processing capabilities limitations constrain the security mechanisms that can be supported.

We consider Software Defined Networking (SDN) and Cloud/Edge computing as the promising technologies to address some of these challenges. SDN provides the capabilities to configure policies and rules along the whole network in a consistent way [1]. SDN, separating control and data planes, is vital to enable dynamic access policies (as well as for the consistency verification and monitoring tasks).

In this paper, we propose a security framework embedded in a global IoT network architecture. The main function of this framework is to perform the AA (Authentication and Authorization) operations. This paper is organized as follows: in section II, we review the most recent security solutions within SDN. Section III introduces our global view of the IoT future network. In section IV, we present our authentication and authorization flow schemes. Section V illustrates the evaluation part. Finally, we conclude in section VI.

II. Literature Review

A. *IoT Security Platform*

In [2, 3], a proposition of a federated SDN based controlled architecture is presented. This architecture consists of multiple IoT domains and security is improved by making the SDN controller a central trusted authority. Thus, the communication between the adjacent IoT domains is done through the edge controllers. While the proposed security solution seems to cope with the scalability issue having multiple IoT controlled domains, it is not clear how the federated layer of controllers is managed. Actually, it is possible to have a malicious controller in a certain domain. So, a higher orchestration layer is needed. The domain size, the presence of multiple controllers in the same domain, the overhead imposed on the device acting as a controller, and the supported security functions are the main limitations of the proposed scheme.

The need to implement the access control in IoT at the network level is discussed in [4]. The authors argue that implementing security functions at the device level, as performed in the current network paradigm, is cumbersome in the IoT case. Many of the IoT things are just sensors and do not have that much processing and storage capacities. In this context, they proposed a new platform to detect attacks at the network level.

The IoT security platform design requirements are discussed in [5, 6]. One of the most important constraints is to have a lightweight security scheme due to the constrained nature of the IoT environment.

B. *Network Access Control (NAC)*

NAC in traditional networks suffers from several issues such as: lack of authorization, network openness, distributed nature of network systems (authorization needs centralization

978-1-5386-2855-3/17/$31.00 ©2017 IEEE

of control), rules and policies inconsistency, static rules and management complexity, and the Policy Enforcement Point localization which presents mostly a bottleneck and a single point of failure. Furthermore, access control in today's networks is limited to firewalls application and access lists in the network elements [7]. Firewalls suffer from the single point of failure and static configuration problems, and ACLs management is complex and error prone [8]. Therefore, introducing SDN is key to hide the complexity in the access control enforcement and management. By introducing SDN flow-based mentality, the access control function can achieve finer granularity. Additionally, the possibility of having different virtual networks on top of the same physical network contributes in separating the users' flows using virtual ports (e.g. VLAN).

FlowNAC is one of the first attempts to model NAC in a flow-based manner [9]. FlowNAC extends 802.1X employing EAPoL-in-EAPoL to differentiate services requested by the same user. Relying on port based access control (PBAC), this model implements the enforcement point as a module in an SDN controller capable of configuring the policies as flows along the data paths. FLowIdentity is another attempt to implement Software-Defined NAC [10]. This work is similar to FlowNAC but with the proposition of an RBAC firewall which provides flexibility and dynamicity in the policy enforcement task.

These are some of the most important works aiming at implementing NAC in a software defined manner showing that network function softwarization. However, these solutions are mainly based on port based access control. IoT calls for a new access control paradigm targeting the application level. Having multiple applications with different level of criticality, we need to have fine-grained control up to the application layer. Recently, Palo alto Networks corporation proposed to integrate App-ID at the network level [11]. Thus, each application having a unique identifier can be granted the correspondent requirements (e.g. QoS) and access permissions.

III. Future Network Architecture

A. *Need for Softwarisation*

As discussed previously, heterogeneity, big data, high scalability, and security and privacy concerns are the main IoT challenges. Having our private assets (healthcare sensors, car, home, etc.) connected to the Internet exposes our private life to serious security and privacy breaches.

In this context, SDN separating the data and control planes allows for more network flexibility, dynamicity, and configurability. The SDN architecture, presented in [12], consists of a data plane composed by managed network elements (switches or routers) and a control plane consisting of a central controller. An application layer, residing on top of the controller, consists of a set of network functions revealing the network programmability. Different application types ranging from simple network monitoring to more critical ones such as security policies' enforcement (e.g. firewall) are supported by this layer. Also, a management plane is added vertically aside to the control plane. This architecture helps in providing management flexibility and network dynamicity (main required aspects for the future network). Along with SDN, NFV is a complementary technology that applies the virtualization concept in the network domain. NFV aims at virtualizing the network functions detaching them from the hardware dependency. Thus, different network functions can be deployed on the same hardware. Slicing, another option provided by the virtualization paradigm, consists of isolating the network instances giving the opportunity to share the same network infrastructure between multiple providers, applications, flows, etc.

On the other hand, advanced technologies for handling IoT big data are required. Cloud computing revealed high effectiveness in this context. Providing Software as a Service (SaaS), Platform as a Service (PaaS), Infrastructure as a Service (IaaS), and more recently, Network as a Service, cloud computing was a revolutionary technology in the last decade. However, centralizing the data storage and analysis at the cloud compromises the network core capability to handle the big amount of generated data in terms of added overhead and latency. Thus, a new technology emerged aiming at pushing data processing and storage to the network edge. Edge/fog computing has been known in the mobile domain by Mobile Edge Computing (MEC). MEC aims at providing cloud-based services at the user's proximity presenting valuable benefits: low latency, augmented reality, location awareness, high throughput, high scalability, etc.

B. *Proposed Hierarchical Control-based IoT Architecture*

Integrating the mentioned enabling technologies, our architecture is composed of six layers: the device layer, the access network layer, the access control layer, the core network layer, the core control layer, and the application layer. Being SDN controlled, this network is not intended to be fully centralized. However, we resort to a hierarchical design to overcome the complexity of a single control level in this highly scalable network [13]. Besides, IoT (along with 5G) is depicted to be the "nervous system" of the digital society [14]. Thus, we tried in this architecture to imitate the human nervous system, which is composed of two levels of control: central (brain and spinal cord) and peripheral (network of nerves), to build an architecture characterized by a hierarchical control design. In our architecture, the brain of the network is the core controller and the spinal cord is the set of access controllers. The peripheral nerves are the devices connected to the access points.

The Device Layer: This layer consists of a set of heterogeneous devices with different capabilities (processing, power, memory, etc.) and different supported access technologies (Wi-Fi, Bluetooth, radio wave, etc.). Thus, different authentication schemes are employed (password, RFID, PIN, challenge/response scheme with symmetric or public/private keys, etc.). In this context, each set of devices will have a certain level of security depending on the authentication scheme it supports and the application it runs. A device could run multiple applications (with different credential profiles) and thus each one will have a different clearance to access different classes of data.

The Access Network Layer: This layer consists of a set of access relay points, which are equipped with SDN enabled network elements: OpenFlow switches, routers, middle boxes, etc. Additionally, these access points are fog enabled and thus they can provide primitive data services (i.e. OpenStack nodes).

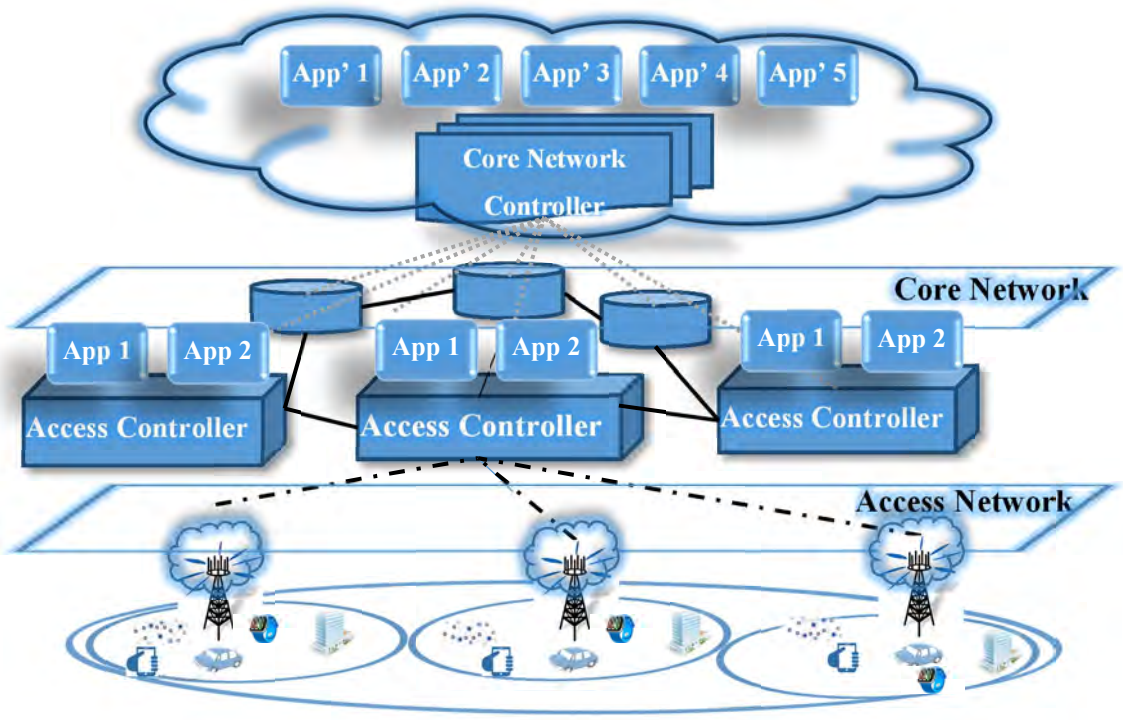

Figure 1: Future Network Architecture

The devices in this layer are managed by the access control layer and thus the access rules of the underlying devices are defined by this control layer and configured accordingly in the devices.

The Access Control Layer: This layer consists of the access control points. These intelligent points include mini SDN controllers that manage the underlying heterogeneous networks. Connected to the core network devices, these software-defined gateways (SD-GWs) are also managed by the upper layer control.

The Core Network Layer: This layer consists of a set of hybrid core network elements that connect the clusters of the access networks. Controlled by the core SDN controller, this layer could employ the autonomic computing paradigm to enable self-management, self-healing, and self-optimization characteristics needed in this large and critical network [15].

The Core Control Layer: This layer is responsible for managing the hybrid core network (SDN and non SDN based devices set: routers, switches, gateways). Having the highest level of security, this layer has the central role of access control management. As well as being aware of all network configurations, authentications, access rules, etc. the core controller has the power to modify or inject new rules in case of malicious behavior detection or any deficiency.

The Application Layer: This layer consists of a set of applications deployed over the virtualized core network. Developed by third party companies, these applications can present serious security risks. Thus, a tight access control is necessary to be integrated within the virtualized managed deployment of these applications over the core and the access networks.

IV. Proposed Security Scheme

There are many access control models: Mandatory Access Control (MAC), Discretionary Access Control (DAC), Role Based Access Control (RBAC), Attribute Based Access Control (ABAC), and Capability Based Access Control (CBAC). MAC was proposed essentially in the military domain. DAC is applied in some operating systems. RBAC is mainly used in the web domain. ABAC recently proposed in the context based security domain to provide dynamic access rules. Most Recently, CBAC has been proposed to cope with the network scalability and configuration flexibility issues.

In our security model, we refer to the architecture presented in section III (Figure 1). We propose to have different access control models in this architecture. The core controller is acting as a global network operating system and presents high criticality, a kind of military security aspect (MAC and/or DAC) is needed there. Few subjects must have permission to access or modify any information at this level. The main entities permitted to interact directly with this entity are the access controllers and the set of critical applications (App's). The Second control level of the network, the access one, is a very dynamic one. So, it needs to apply a dynamic access control model. RBAC or CBAC combined with ABAC would fit these requirements.

Thus, each thing after having registered and given its initial credentials, it will be assigned a security level (in our case, it will be assigned a role and permissions). This level depends on the thing capabilities (processing, power, and storage) which

affect its authentication faithfulness. Accordingly, it will be assigned permissions with respect to its capabilities and its installed applications. Similarly, each application will be granted certain capabilities to access network resources (similar to the mobile applications authorization process).

Each device connected to the IoT network has specific capabilities and thus each one will be assigned a certain level of security accordingly. On the other hand, the set of resources (data, processes, bandwidth, etc.) has different levels of criticalities and thus each set of resources will have a certain security classification level. In our model, the classification of both subjects and resources are performed by the central core controller. Different levels of security (e.g. multiple applications profiles) at the same device might invoke the multi-level authentication principle and thus at each level, different access rules are included.

The proposed architecture allows for the distribution of access control configurations, so, when a subject requires access to a certain object, it sends the request to the nearest access point which looks for a rule (in case of communication resource) in its forwarding table. If it does not find the correspondent one, it will ask the access controller. If the access controller has the correspondent configuration, it will reply accordingly. If not, it will forward the request to the core controller through the core network. Thus, the core controller will check if the subject has the permission to access the target object with respect to the defined properties and security rules with the actual session security function values. But, in either case, it will send a response back to the access point through the access controller. Thus, once configured for the first time, the subject at the second access has only to ask the correspondent access point (if it is not mobile). In case of mobility, a communication between the old and new access points could solve this issue. Pushing the access control configurations to the network edge saves time and bandwidth in comparison to a fully centralized control scheme. Additionally, the access controller can have a role in making the decision if configured by the corresponding security functions and rules.

As we mentioned before, the subject's security level per application is a function of the subject 's supported authentication scheme and the running application profile. So, the same application deployed on different assets will not have the same access permissions and thus this helps in preventing weak authenticated devices from breaking the system confidentiality (for some object security levels). Additionally, we consider the request as being processed per application per session. So, there is no static subject security level. Furthermore, it is granular to the application level.

A. *Initial Registration, Authentication, and Authorization.*

In Figure 2, we present the initial authentication process that takes place between the different network elements. Initially, each AC must be authenticated and certificated by the Core Controller (CC). Note that in our case, we assume that CC is a trusted party. After authenticating the AC, providing it a certification that is saved in a global database and in the AC local database, each SD-GW has to be authenticated by the AC and the CC. Hence, after being discovered by the AC, the SD-GW sends an authentication request to the AC. For the first time, the AC forwards this request to the CC entity. The CC must authenticate first the AC forwarding the request by verifying the request accompanied certificate.

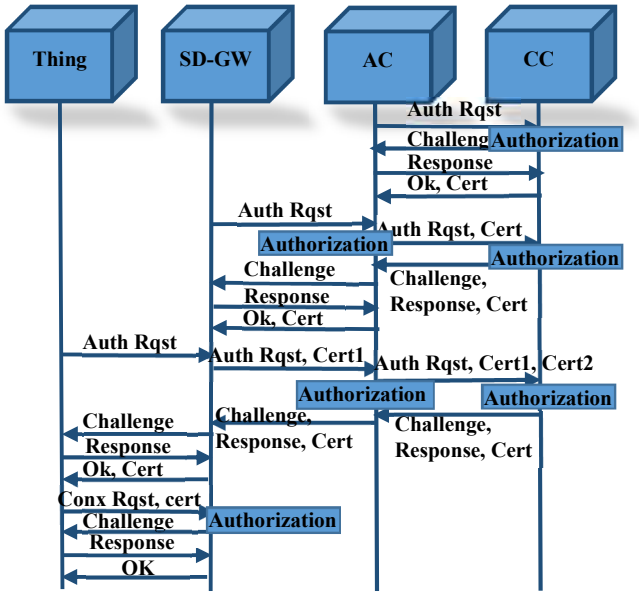

Figure 2: Initial Authentication Scheme

Then, it must authenticate and generate the certification for the SD-GW, which will be stored in the global database, the local AC database and the local SD-GW database. Note that the keys might be generated by the SD-GW, AC or CC but the certifications are exclusively generated by the CC. After being authenticated by the AC, the SD-GW is ready to authenticate the user devices. When a new user device wants to connect to the mobile network, it must initiate an authentication request toward the SD-GW which in turn forwards this request to the AC forwarding it to the CC after checking the SD-GW certificate. The same process takes place, so the CC makes sure of the correctness of the AC and SD-GW certificates (Cert1 and Cert2) and returns to the AC the challenge response values and the user device certificate, which must be forwarded back to the user device and stored at each level. When receiving the certificate and the authentication challenge, the user device responds by sending the response to the SD-GW. Upon receiving the correct response, the SD-GW authenticates the device by an OK reply. This process takes place only once when the user connects for the first time to its Home Network. However, the second time, as shown in the last part of the messages exchange, Figure 2, the user device is authenticated directly with the SD-GW point.

B. *Intra-domain Authentication and Authorization Delegation.*

In the second case (Figure 3), the "Thing" is moving from one cell to another. In this case, the SD-GWs being authenticated by the AC, they can perform a mutual authentication using their stored certifications. Initially, when a handover occurs, the old SD-GW initiates a handover request to the new SD-GW. Thus, after the mutual authentication phase, the old SD-GW sends the "Thing" credentials to the new SD-GW. Consequently, when the "Thing" tries to connect to

the new SD-AP, it will be authenticated correctly. Finally, after the handover is performed, the new SD-AP updates the AC

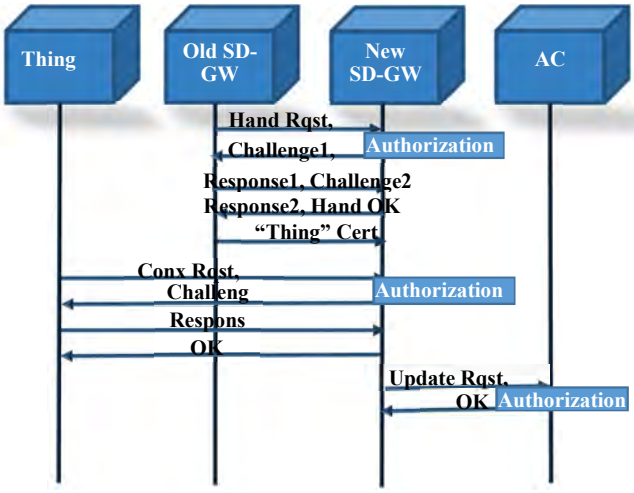

Figure 3: Handling Authentication with intra domain mobility

about the new "Thing" location. When launching the update, the new SD-GW must be authenticated also by the AC. In its turn, the AC must send in its periodic update the new "Thing" location to the CC.

C. *Inter-domains Authentication and Authorization Delegation.*

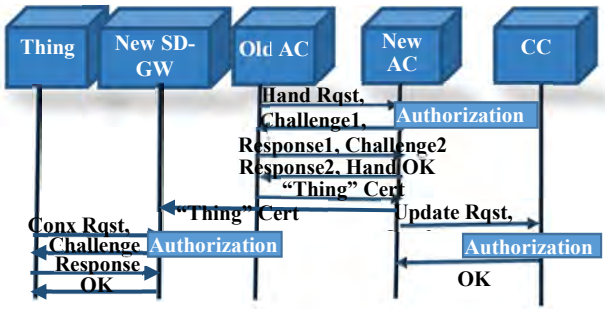

Figure 4: Handling Authentication with inter domains mobility

In this case, the "Thing" moves form AC domain to another AC domain (Figure 4). The same process performed in the previous case between SD-GWs must be performed between the involved ACs. Additionally, the new AC must provide the "Thing" certificate to the new SD-GW. Thus, when the "Thing" requests a connection to the new SD-GW, it can be authenticated by the corresponding certificate. Finally, the new AC must update the CC about the "Thing" location.

V. Analysis

We tested our scheme using the AVISPA (Automated Validation of Internet Security Protocols and Applications) tool. This tool uses HLPSL (High Level Protocols Specification Language), a high-level role-based language which permits the description of the security protocol using roles. The translator HLPSLIF transforms the high-level protocol description in an intermediate format (IF), which is then passed to one of four backend modules. These modules are: The On−the−fly Model−Checker (OFCM), the CL−based Attack Searcher (CL-ATSe), the SAT−based Model−Checker (SATMC), and the Tree Automata−based Protocol Analyzer (TA4SP). The default backend is the OFCM. These back-ends test if the security goals are satisfied or violated [16]. The HLPSL file defines the protocol's agents as roles. Each role has certain parameters passed to it from other roles, an initial state, and several steps can be defined where transition from state to state is done at specific events (sending or receiving messages). Each role description is defined by having local variables and initial parameters passed to it as parameters. The session declaration encompasses all the agents, keys, identities, and functions declared in the knowledge of each role. The session role allows different roles to work in parallel [17].

Testing was performed using the SPAN/AVISPA virtual box (VBox) disk image on a virtual machine. SPAN is a Security Protocol Animator; it provides a high-level interface where the user inputs the protocol description in the CAS language, which is then automatically transformed into an HLPSL file [16].

In our CAS file, we defined the core controller, the access controller, the gateway and the thing as users, their public keys, the used numbers and hash functions in the identifiers section. In the messages section, we defined the exchanged messages between users. In the knowledge section, we defined the knowledge of each user. In the session section, we instantiate the session variables. We have defined also the intruder knowledge and finally the goals. In the generated HLPSL file, we have three roles: **Thing (T), Gateway (GW), Access Controller (AC), and Core Controller (CC).** Each role has certain knowledge, initial state, and several transitions defined in its role section. The session initialization is performed in the environment role where the global variables are defined.

This HLPSL file is translated into an IF file. The analysis, which is fully automated, is executed on the IF protocol description file. In our testing, we have applied two backend checkers (OFCM & CL_ATSE) to this file. The results show that our scheme is **SAFE** against attacks.

The main concept of these checkers is that they look for possible attacks simulating the role of an intruder. The analysis considers the channels as insecure mediums and all unencrypted messages or encrypted messages with attainable keys can be perceived by the intruder. So, these testing algorithms try to test if the defined security goals in the HLPSLIF file can be violated by introducing the intruder role or not. Upon the analysis, they decide if the protocol is SAFE, UNSAFE, or INCONCLUSIVE. The main attacks that are considered by these testing/verification algorithms are: unauthorized access, masquerade, man-in-the-middle and replay attacks.

VI. Conclusion

In this paper, we have defined the essential security functions needed to be implemented in any IoT architecture. Authentication and authorization are two main security functions to ensure authorized access to network resources. These are primitive and unavoidable security practices. SDN & NFV, and cloud/edge computing are the enablers of the IoT due to their capability to overcome the unpreceded added

complexity. Consequently, a new architecture integrating these technologies is proposed in this paper. This architecture, imitating the human nervous system, presents two levels of control in a hierarchical way. The SDN control, integrated in the proposed architecture, besides having a global view of the network, it helps in providing flexibility to apply any change or to verify the correctness of the system behavior.

ACKNOWLEDGMENTS

Research funded by TELUS Corp., Canada

REFERENCES

[1] V. Dangovas and F. Kuliesius, "SDN-driven authentication and access control system." In *The International Conference on Digital Information, Networking, and Wireless Communications (DINWC)*, p. 20. Society of Digital Information and Wireless Communication, 2014.

[2] O. Flauzac, C. González, A. Hachani and F. Nolot, "SDN Based Architecture for IoT and Improvement of the Security," *2015 IEEE 29th International Conference on Advanced Information Networking and Applications Workshops*, Gwangiu, 2015, pp. 688-693.

[3] F. Olivier, G. Carlos and N. Florent, "'New Security Architecture for IoT Network," *Procedia Computer Science*, vol. 52, pp. 1028-1033.

[4] V. Sivaraman, H. H. Gharakheili, A. Vishwanath, R. Boreli and O. Mehani, "Network-level security and privacy control for smart-home IoT devices," *2015 IEEE 11th International Conference on Wireless and Mobile Computing, Networking and Communications (WiMob)*, Abu Dhabi, 2015, pp. 163-167.

[5] R. T. Tiburski, L. A. Amaral, E. de Matos, D. F. G. de Azevedo and F. Hessel, "The Role of Lightweight Approaches Towards the Standardization of a Security Architecture for IoT Middleware Systems," in IEEE Communications Magazine, vol. 54, no. 12, pp. 56-62, December 2016.

[6] J. L. Hernández-Ramos, M. P. Pawlowski, A. J. Jara, A. F. Skarmeta and L. Ladid, "Toward a Lightweight Authentication and Authorization Framework for Smart Objects," in IEEE Journal on Selected Areas in Communications, vol. 33, no. 4, pp. 690-702, April 2015.

[7] I. Amdouni, F. Hrizi, A. Laouiti, E. Grasa and H. Chaouchi, "Exploring the flexibility of network access control in the recursive InterNetwork Architecture," *2016 22nd Asia-Pacific Conference on Communications (APCC)*, Yogyakarta, Indonesia, 2016, pp. 559-566.

[8] M. Belhaouane, J. Garcia-Alfaro and H. Debar, "On the Isofunctionality of Network Access Control Lists," *Availability, Reliability and Security (ARES), 2015 10th International Conference on*, Toulouse, 2015, pp. 168-173.

[9] J. Matias, J. Garay, A. Mendiola, N. Toledo and E. Jacob, "FlowNAC: Flow-based Network Access Control," *2014 Third European Workshop on Software Defined Networks*, Budapest, 2014, pp. 79-84.

[10] S. T. Yakasai and C. G. Guy, "FlowIdentity: Software-defined network access control," *Network Function Virtualization and Software Defined Network (NFV-SDN), 2015 IEEE Conference on*, San Francisco, CA, 2015, pp. 115-120.

[11] https://www.paloaltonetworks.com/technologies/app-id.

[12] https://tools.ietf.org/html/rfc7426.

[13] D. TABAK, "'A Review of: "THEORY OF HIERARCHICAL, MULTILEVEL SYSTEMS", by M. D. Mesarovic, D. Macko and Y. Takahara. Academic Press, New York, 1970. 294 pp," *International Journal of General Systems*, vol. 2, no. 1, 01/01, pp. 55-56.

[14] D. Soldani and A. Manzalini, "'5G: The Nervous System of the True Digital Society," *E-LETTER*.

[15] https://tools.ietf.org/html/rfc7575.

[16] http://www.avispa-project.org/package/tutorial.pdf.

[17] http://www.avispa-project.org/package/user-manual.pdf.